

03/06/2026

Analisi Malware

WannaCrypt0r.exe

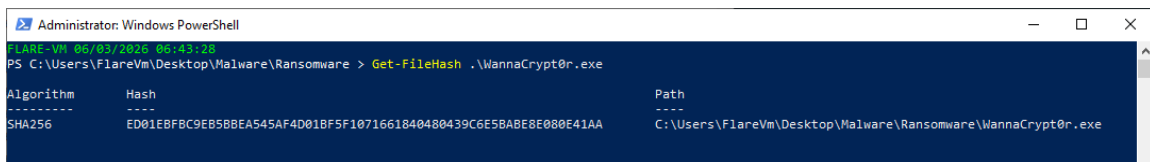
Lorenzo Sanna
EPICODE

Introduzione e Metodologia

Il presente report illustra l'analisi tecnica condotta sul campione malware denominato 'WannaCrypt0r.exe'. In ottemperanza alle direttive di sicurezza e alla traccia dell'esercizio, l'eseguibile non è stato avviato sulla macchina virtuale locale (FlareVM). L'analisi è stata invece delegata alla piattaforma di sandboxing cloud-based Tria.ge. Questo approccio ha permesso di eseguire il malware in un ambiente isolato e controllato, raccogliendo preziose informazioni sulle sue caratteristiche statiche, sul comportamento a runtime e sulle comunicazioni di rete.

Identificazione del Campione (Analisi Statica di Base)

Il primo passo dell'analisi consisteva nell'identificazione univoca del file tramite l'hashing. Come calcolato tramite PowerShell (cmdlet Get-FileHash) sulla macchina FlareVM, l'hash SHA-256 del campione è fondamentale per la ricerca su database di Threat Intelligence.



```
Administrator: Windows PowerShell
FLARE-VM 06/03/2026 06:43:28
PS C:\Users\FlareVm\Desktop\Malware\Ransomware > Get-FileHash .\WannaCrypt0r.exe

Algorithm      Hash                                     Path
-----
SHA256         ED01E8F8C9EB58BEA545AF4D01BF5F1071661840480439C6E5B8ABE8E080E41AA  C:\Users\FlareVm\Desktop\Malware\Ransomware\WannaCrypt0r.exe
```

Figura 1: Calcolo dell'hash SHA-256 su FlareVM

Analisi della Struttura PE (Headers, Sezioni, Subtype)

Attraverso l'analisi statica su Tria.ge, è stato possibile ispezionare la struttura del file eseguibile (PE). Il file risulta sprovvisto di firma Authenticode (Unsigned PE), un indicatore comune di file sospetti o non verificati. Le sezioni del file (.text, .rdata, .data, .rsrc) mostrano una struttura standard per gli eseguibili Windows, ma con una sezione '.rsrc' (risorse) significativamente grande, il che suggerisce che il malware possa contenere altri file, eseguibili droppati o payload compressi al suo interno.

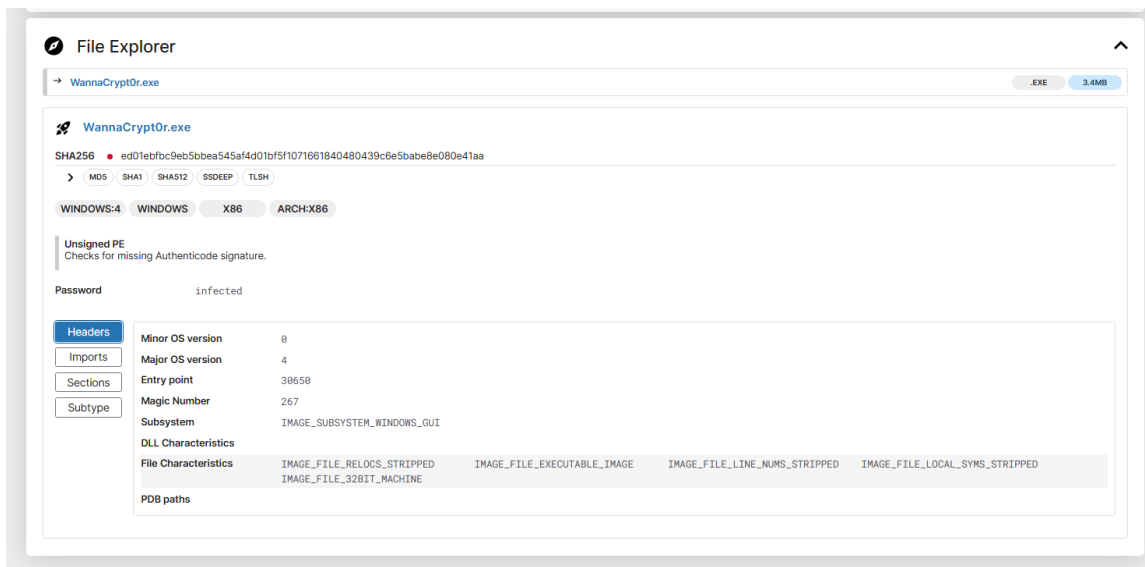


Figura 2: Analisi degli Header del file PE

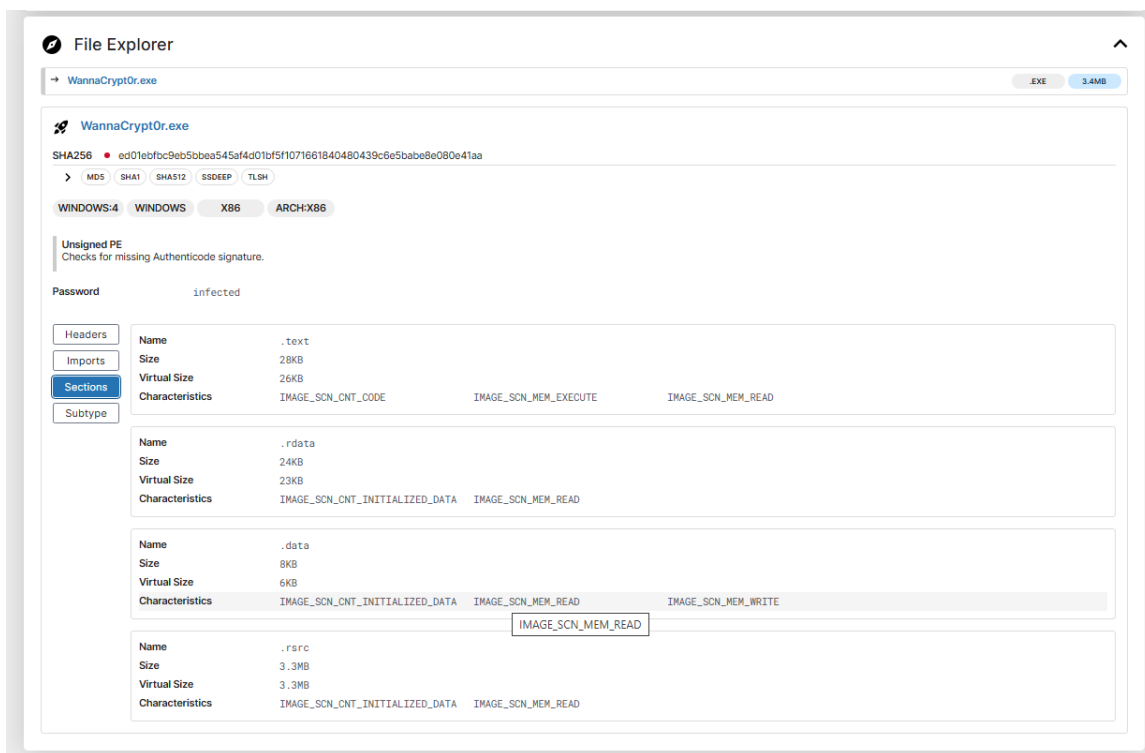


Figura 3: Analisi delle sezioni del PE (notare la dimensione di .rsrc)

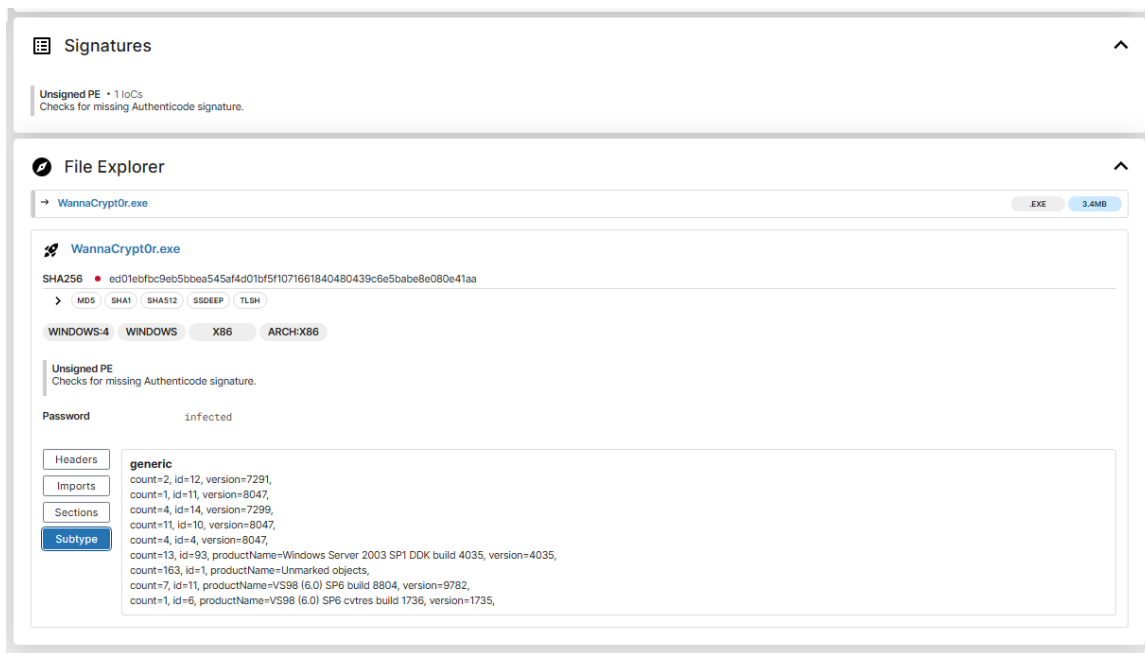


Figura 4: Dettagli Subtype e rilevamento Unsigned PE

Esecuzione Dinamica in Sandbox (Tria.ge)

L'avvio del file nella sandbox ha confermato immediatamente la sua natura di ransomware. La piattaforma ha assegnato un punteggio di minaccia di 10/10, classificando il malware nelle categorie WANNACRY, RANSOMWARE e WORM. A livello visivo, il malware ha modificato lo sfondo del desktop e mostrato la famigerata interfaccia di decrittazione (ransom note) che richiede il pagamento di 300\$ in Bitcoin. È stato inoltre estratto il testo di configurazione della ransom note.

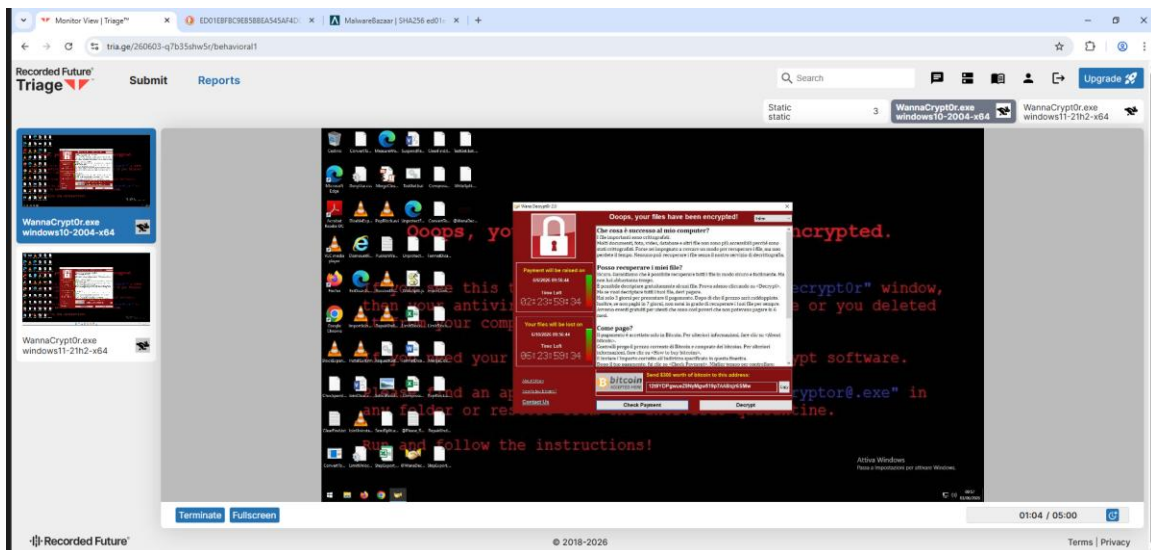


Figura 5: Esecuzione del ransomware e comparsa della schermata di riscatto (Ransom note)

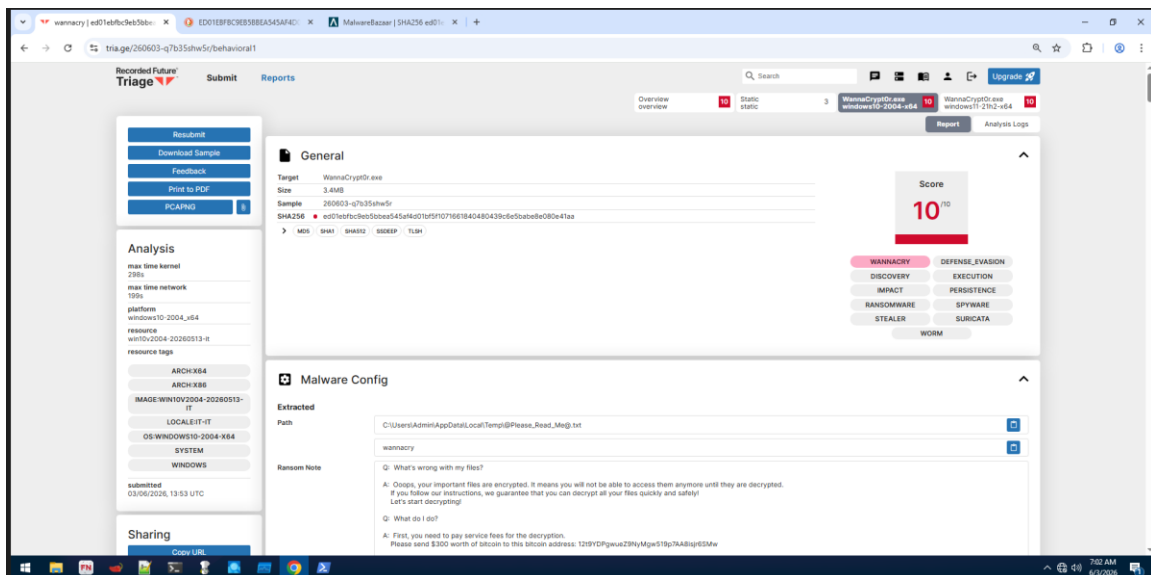


Figura 6: Report riassuntivo Tria.ge, punteggio 10/10 e configurazione estratta

Analisi del Traffico di Rete

L'analisi dinamica ha tracciato numerose attività di rete. Tra queste spiccano richieste DNS verso domini apparentemente casuali o servizi di terze parti, spesso utilizzate dal malware come 'Kill Switch' per verificare se si trova in un ambiente isolato o per interrompere l'infezione. Sono state rilevate numerose connessioni TCP (su porte 80 e 443) e richieste UDP (prevalentemente traffico DNS sulla porta 53).

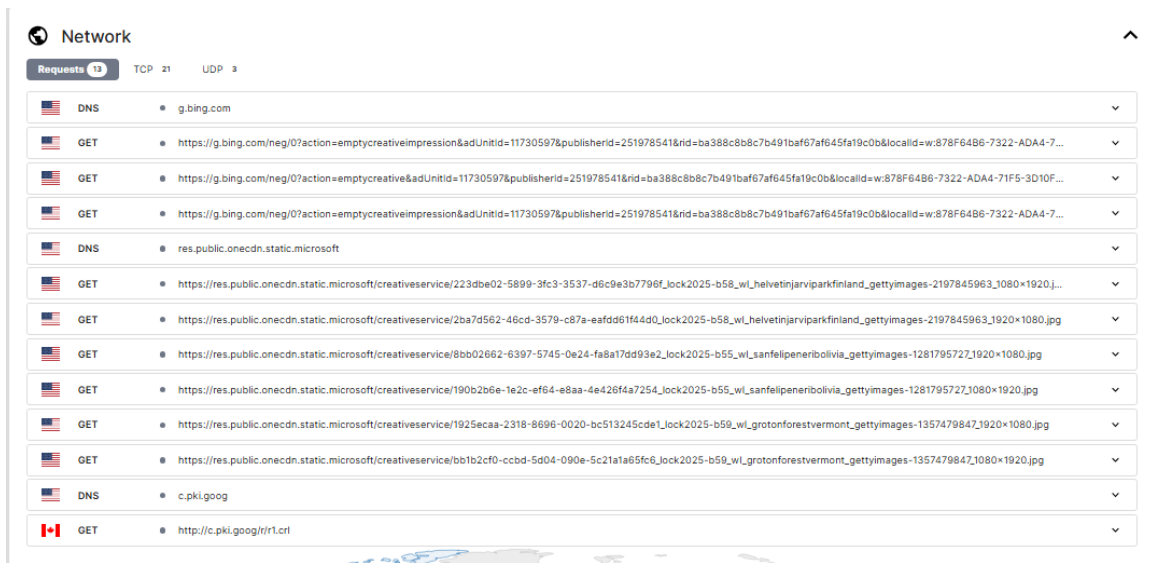


Figura 7: Panoramica delle richieste HTTP/GET ed espansioni DNS

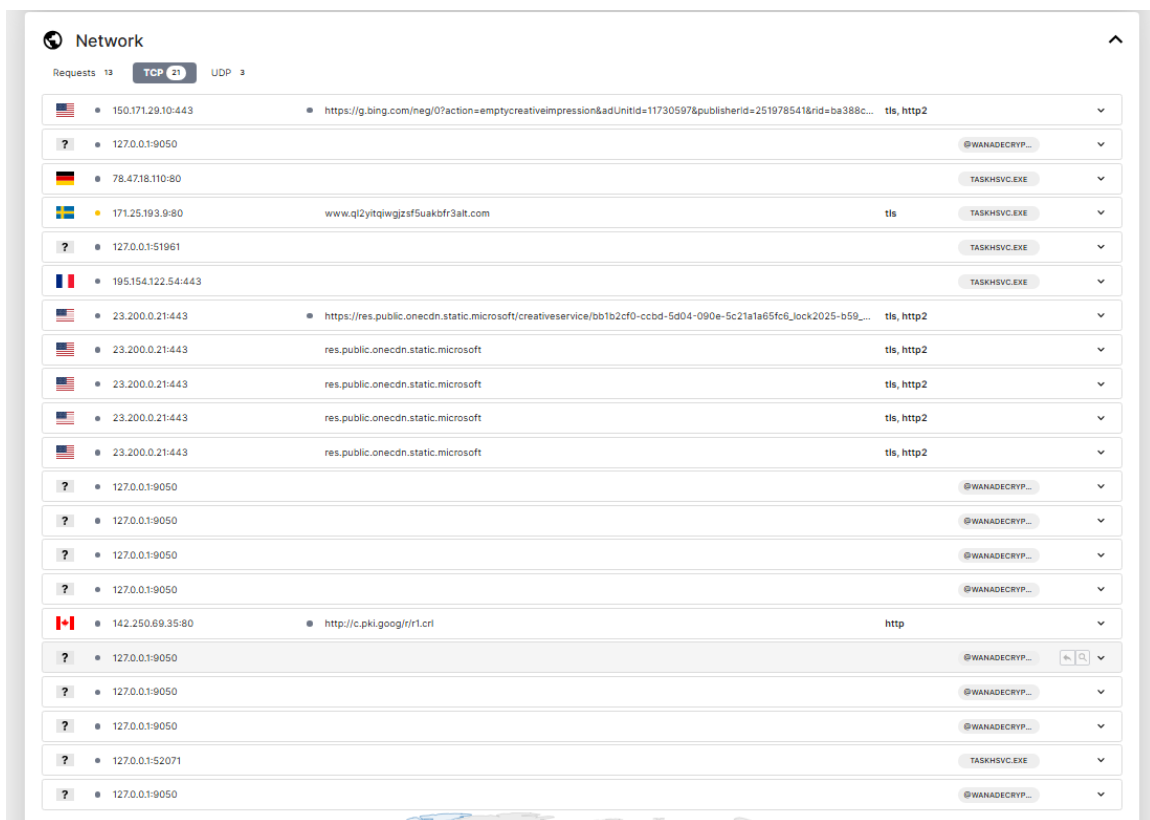
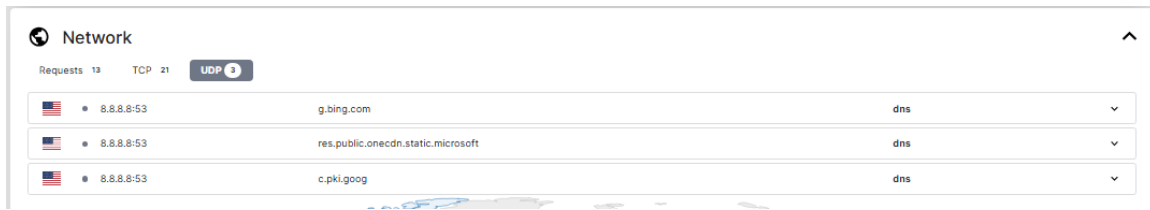


Figura 8: Connessioni TCP instaurate dai processi generati (es. taskhsvc.exe)



Network			
Requests 13 TCP 21 UDP 1			
🇺🇸	8.8.8.8:53	g.bing.com	dns
🇺🇸	8.8.8.8:53	res.public.onecdn.static.microsoft	dns
🇺🇸	8.8.8.8:53	c.pki.goog	dns

Figura 9: Risoluzioni DNS su protocollo UDP (porta 53)

Firme Comportamentali e Indicatori di Compromissione (IoC)

La sandbox ha registrato in modo automatico diverse 'Signatures' che definiscono la gravità del malware. Tra le tecniche classificate secondo il framework MITRE ATT&CK figurano:

- Impact & Defense Evasion: Cancellazione delle copie shadow (Deletes shadow copies) tramite vssadmin o wmic, impedendo il ripristino dei file.
- Persistence: Creazione di chiavi di registro (Run keys) per l'avvio automatico e drop di file eseguibili.
- Discovery & Collection: Enumerazione dei processi, lettura di file di configurazione dei browser e modifica dei permessi su file e directory.

Viene inoltre generato un allarme Suricata per la rilevazione di pattern riconducibili a nodi Tor, suggerendo che il malware tenta di comunicare con server di comando e controllo (C2) su darknet.

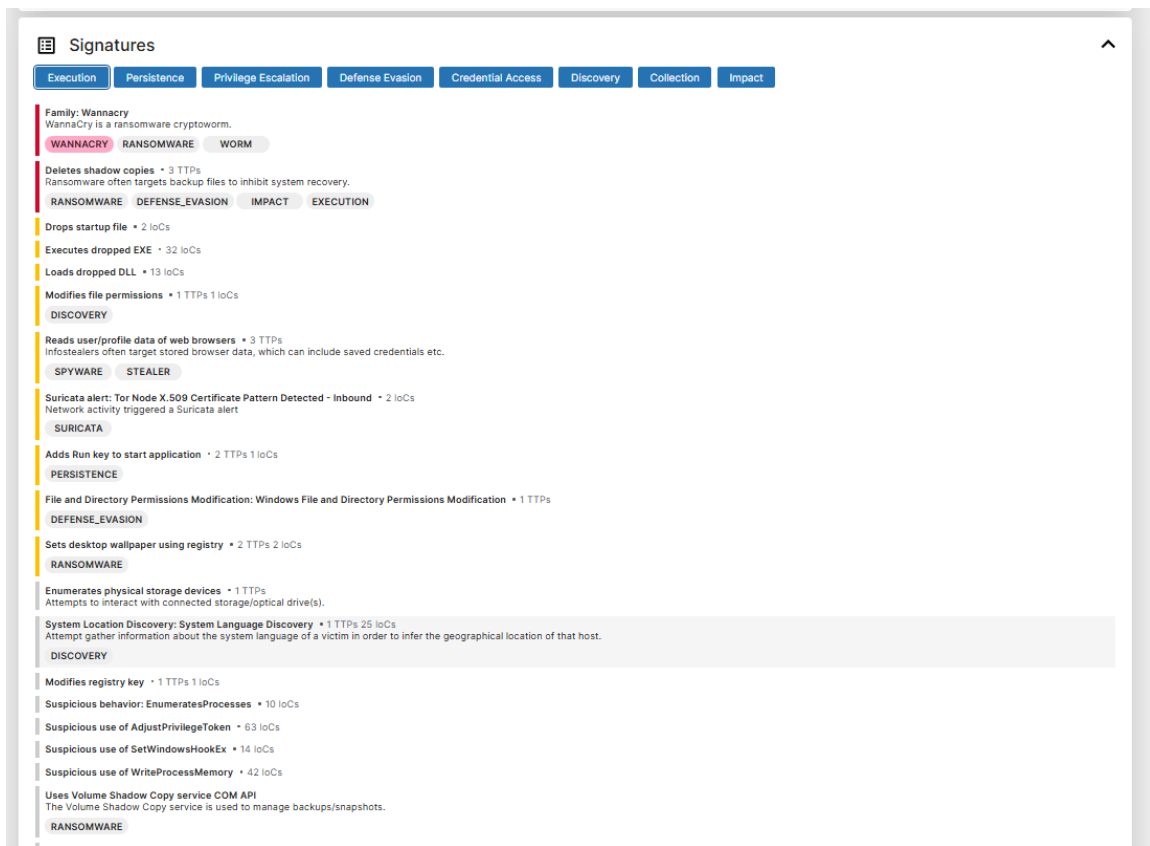


Figura 10: Firme comportamentali rilevate (Signatures)

7. Conclusioni

L'analisi ha confermato che l'eseguibile WannaCrypt0r.exe è un grave ransomware con capacità da worm (famiglia WannaCry). Tramite l'uso di piattaforme sicure come Tria.ge, è stato possibile identificare non solo le caratteristiche statiche ma anche gli elementi chiave del comportamento distruttivo: connessioni di rete evasive, modifica delle impostazioni di sistema, eliminazione di backup locali e crittografia dei dati a scopo di estorsione. I dati raccolti (IoC, Hash, domini) risultano pronti per essere integrati in sistemi di sicurezza (EDR/SIEM) per prevenire future infezioni.